

CORRALIGN PLATFORM

LLM Enterprise Identity Control Model

Technical Architecture Reference

Subsection: Identity-Aware Authorization, Model-Tier Routing & Audit Controls

Classification	Confidential — Internal
Status	Active — Phase 1 Implemented
Platform	william-platform (AWS)

1. Purpose & Scope

This document defines the core infrastructure pattern for secure, enterprise-grade LLM access across the Corralign platform. It specifies the design, components, and implementation state of the identity-aware authorization model, model-tier routing system, and audit-grade controls that govern all LLM invocations.

This section covers the following integrated surfaces:

- Web widget client
- Microsoft 365 integrations (Word, Teams, Outlook)
- Copilot Studio
- Direct REST API integrations

SCOPE

This document is a subsection of the broader Corralign Platform architecture. It focuses specifically on LLM access governance and should be read alongside the identity federation and data classification documentation.

2. Core Design Principles

The following principles govern all architectural and implementation decisions within this subsystem:

Principle	Description
Single Policy Decision Point	All model invocations pass through one authorization gate before execution. No path bypasses the policy engine.
Deny by Default	Requests with unresolved identity, unapproved purpose, or model tier mismatch are denied automatically.
Separation of Concerns	Perimeter security, identity enrichment, policy evaluation, model routing, and output controls are distinct, independently governed layers.
Immutable Audit Trail	Every allow/deny decision is recorded in a queryable, immutable log. No decision is untracked.
Enterprise Integration First	Identity and access controls operate equivalently for human users and automated service agents.

3. Reference Architecture

The architecture is organized into five sequentially executed layers. Each layer has exclusive responsibility for a defined set of controls and passes a normalized context object to the next. The diagram below shows the full layered topology from client surfaces through to the audit sink.

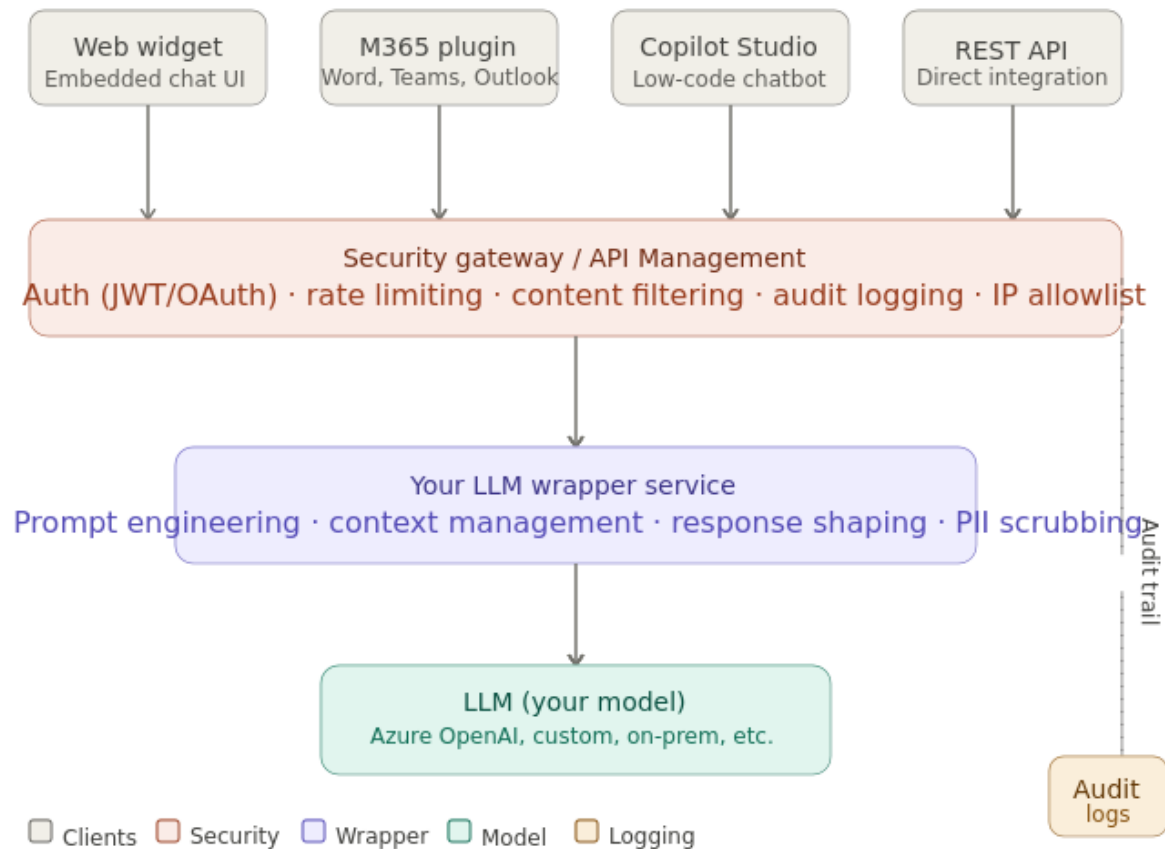


Figure 1 — LLM Security Architecture: Layered topology (clients → gateway → model → audit)

3.1 Client and Ingress Layer

The ingress layer is responsible for all perimeter-level controls before a request is admitted to the identity and policy pipeline.

Supported client surfaces:

- Web widget
- Microsoft 365 plugin surfaces (Word, Teams, Outlook)
- Copilot Studio
- Direct REST API integrations

Ingress control responsibilities:

- JWT / OAuth token validation
- mTLS enforcement and IP/allowlist controls (where required by client configuration)
- Rate limiting and abuse signal detection
- Content pre-filtering and request shape validation

3.2 Identity Enrichment Layer

Inbound request identity is normalized into a common context object that is consumed by all downstream layers. This layer resolves raw token claims into a structured representation of the actor and their operational context.

Context Field	Source	Usage
Subject (sub, email, workload ID)	JWT claims	Actor identification for audit and policy
Groups / Roles	Token groups, Entra claims	Department + enterprise role resolution
Clearance / Data Tier Eligibility	Policy table	Determines accessible model tiers
Purpose / Task Context	Request payload	Purpose-based policy evaluation
Runtime Context	Request metadata	Device posture, source IP, time window, break-glass flag

3.3 Policy Decision Layer

The policy decision layer executes parallel checks against the normalized context object. It is the single gate through which all model invocations must pass. The sequence diagram below illustrates the runtime allow/deny decision flow, including the branching logic for each check.

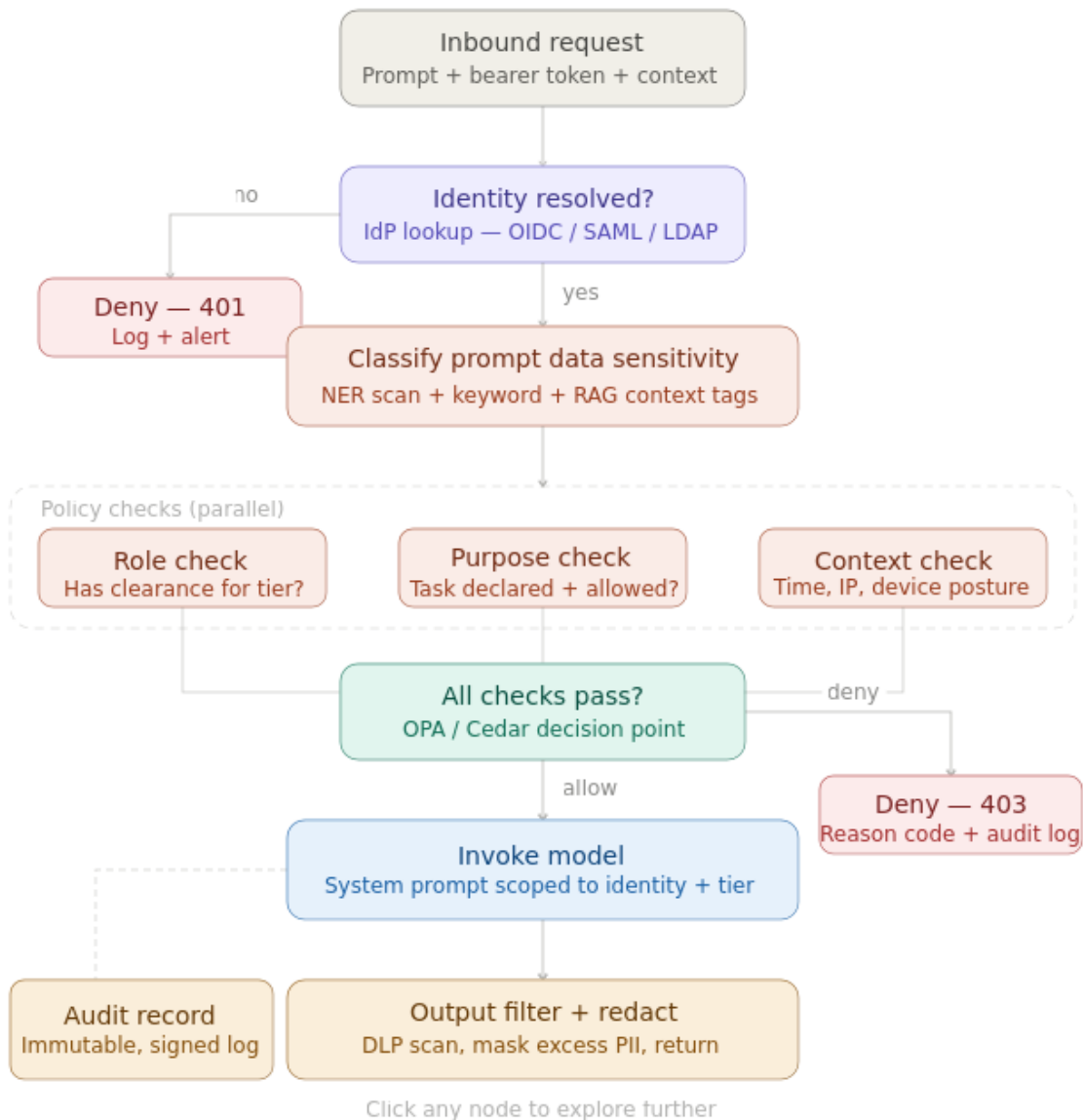


Figure 2 — Identity Request Decision Flow: Runtime allow/deny sequence across role, purpose, and context checks

Check	Evaluation	Failure Outcome
Role Check	Does the actor's role permit access to the requested data tier and model tier?	403 Forbidden
Purpose Check	Is the declared task purpose permitted for this actor and requested resource?	403 Forbidden
Context Check	Does the runtime context satisfy applicable policy constraints (time window, IP, device, MFA, posture)?	403 Forbidden
Identity Resolution	Can identity be resolved from the inbound token?	401 Unauthorized

POLICY BEHAVIOR	An allow decision with scoped constraints is issued only when all required checks pass. Partial pass is treated as deny. All deny outcomes are reason-coded for audit and upstream error messaging.
------------------------	---

3.4 Model Router and Model Tiers

Model selection occurs after a policy allow decision. The router consumes the enriched context and selects the appropriate model tier based on data classification, declared purpose, and risk posture. The architecture diagram below shows the full identity enrichment, policy engine, and model-tier routing topology including output controls.

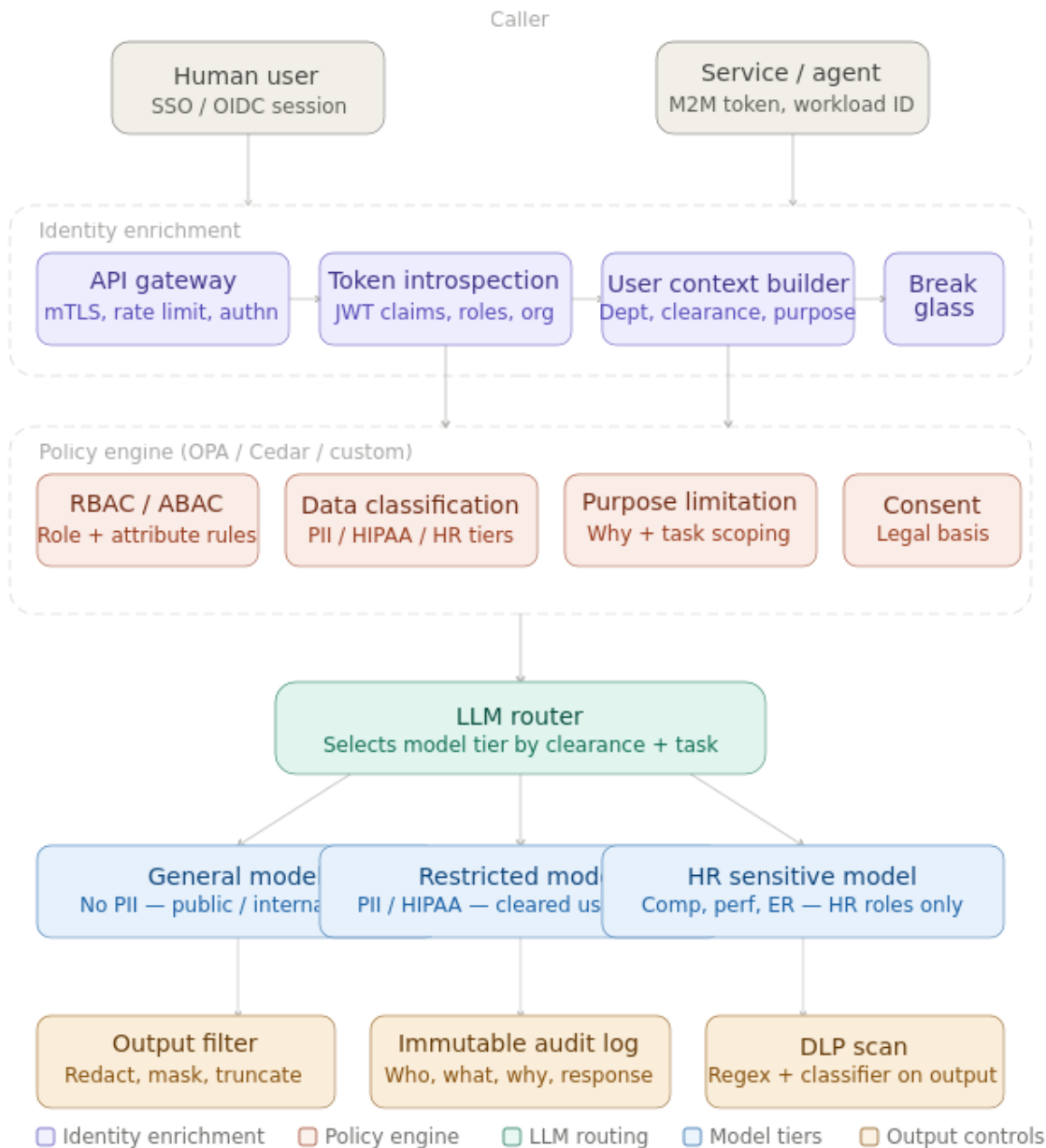


Figure 3 — Identity Access Architecture: Identity enrichment, policy engine, model-tier routing, and output controls

Model Tier	Applicable Workloads	Routing Inputs
General	Non-sensitive, public, and internal-use workloads	Allowed model list, low data classification tag

Model Tier	Applicable Workloads	Routing Inputs
Restricted	PII, HIPAA, or equivalent sensitive workloads	Restricted model allow list, elevated data classification, purpose match
HR-Sensitive	Compensation, performance, employee relations	HR group membership, HR-specific model policy, elevated purpose control

Additional routing inputs: denied model list, data classification tags, declared task purpose, and runtime risk posture score.

3.5 Output Governance and Audit

Before any response is returned to the calling client, it passes through the output governance layer. This layer enforces response-level controls and writes the immutable audit record.

- Output controls applied:
- Output DLP scan
 - Redaction, masking, or truncation of sensitive fields
 - Response policy enforcement (content and format constraints)

Dimension	Fields Recorded
Who	Subject, groups, source application, device / IP context
What	Model requested, model actually used, prompt classification, policy checks executed
Why	Declared purpose and reason code
Outcome	Allow / deny result, response metadata, token usage, stop reason

4. Current AWS Implementation State

The following components are implemented in the william-platform and constitute the Phase 1 baseline:

4.1 Implemented Components

- JWT-protected LLM API endpoints: /v1/llm/models, /v1/llm/invoke, /v1/llm/model-access-policy
- Cognito-backed identity claims and group parsing
- model_access_policy DynamoDB table for subject- and group-based model allow/deny
- Decision logging for authorization outcomes
- Bedrock runtime invoke path with mode-based inference configuration
- IAM and deployment hardening around shared API key retrieval from Secrets Manager

4.2 Recommended Next Hardening Steps

PHASE
1 → 2

The following items are recommended for the transition from Phase 1 to Phase 2. They do not require rearchitecting the current implementation—each can be introduced incrementally.

- Add explicit purpose claims to request payloads and evaluate them in policy engine (not solely via model allowlists)
- Add context-aware checks for device posture, source network classification, and trusted session age
- Externalize policy logic to a dedicated PDP engine (OPA or Cedar) while retaining the existing DynamoDB table as the policy data source
- Sign and hash critical audit events and route them to an immutable log sink for compliance-grade retention

5. Office Suite Enterprise Control Integration

This section specifies how Microsoft 365 surfaces (Word, Teams, Outlook, Copilot Studio) are rewired from app-level convenience integrations into the centrally governed Corralign control model.

5.1 Control Pattern: Federated Identity

Corralign functions as the control plane and policy decision point. Microsoft Entra ID is federated as the identity provider for Office surfaces. The trust model is as follows:

- Entra ID issues user identity tokens and conditional access results
- Corralign normalizes Entra claims and group memberships into its internal context model
- Corralign remains the runtime PDP and PIP for all model authorization decisions

5.2 Entra-to-Corralign Claim Mapping

Entra Claim / Group	Corralign Context Field	Effect
Group: HR-Analysts	group: HR	Enables HR-sensitive model tier access
device_compliant=true	context: device_trust=pass	Satisfies device posture check
mfa=required+satisfied	policy: mfa_present=true	Satisfies MFA policy condition
App ID: teams-plugin-prod	client_scope: teams	Scopes allowed purposes to Teams surface

5.3 Required Office Integration Controls

- Enterprise app registration per Office integration surface
- Strict delegated permissions — minimize application permissions
- Conditional Access policies: MFA, compliant device, trusted network, session controls
- Sensitivity label and Purview DLP integration for prompt and response handling
- Tenant-level consent governance and approved plugin catalog
- Break-glass workflows with dual approval and elevated audit

5.4 End-to-End Flow: Office User Request

Step	Action
1	User authenticates into Office client via Entra SSO
2	Office plugin obtains delegated access token and calls Corralign gateway
3	Gateway validates token, enriches identity, and builds the normalized request context
4	Policy engine evaluates: role check + purpose check + runtime context check + model policy
5	On allow: router selects appropriate model tier and invokes Bedrock runtime
6	Response passes output DLP and redaction controls, then is returned to the Office client
7	Immutable audit event is written with full correlation IDs across gateway, policy, and model invoke

6. Policy and Data Contracts

The following fields are required at minimum for policy evaluation and request processing. All fields must be present for a request to be admitted to the policy engine.

6.1 Required Policy Record Fields

Field	Description
subject	Unique actor identifier (sub, email, or workload ID)
groups	Array of group and role memberships for this subject
allowed_models	Explicit list of model IDs this subject/group may invoke
denied_models	Explicit deny list; takes precedence over allowed_models
allowed_purposes	Permitted task purpose codes for this policy record
sensitivity_max	Maximum data sensitivity tier this subject may process
context_constraints	Runtime conditions: MFA required, device trust, network range, time window

6.2 Required Request Fields

Field	Description
model_id	Requested model identifier; validated against policy allow/deny list
prompt	Prompt payload; subject to pre-filter and output DLP
mode	Inference mode; maps to Bedrock invocation configuration
session_id	Caller session identifier for correlation
request_id	Unique replay-safe request identifier; used for trace correlation
purpose	Declared task purpose code; evaluated against allowed_purposes in policy
client_app	Source application identifier (e.g., teams-plugin-prod, web-widget)

7. Operational Controls

7.1 SLOs and Performance

- Policy decision latency SLO: defined per environment; monitor P95 and P99
- Model invocation latency SLO: inclusive of Bedrock round-trip; alert on sustained threshold breach
- Quota-aware error handling for Bedrock throttling and provider outages

7.2 Alerting

- Deny spike detection: alert on anomalous increase in 401/403 rates
- Anomalous model usage: alert on unexpected model tier access patterns
- Break-glass event alerting: all break-glass invocations trigger immediate notification

7.3 Request Traceability

- Replay-safe request IDs required on all requests
- Trace correlation IDs propagated across gateway, policy engine, and model invoke layers
- All correlation IDs included in the audit record

8. Implementation Phases

Phase	Status	Scope
Phase 1	Current / Implemented	Cognito JWT + model allow/deny enforcement. Purpose field and reason-coded deny responses. UI messaging for quota and approval states.
Phase 2	Planned	Entra federation and claim normalization for Office clients. Conditional access and device posture context checks. Policy engine externalization to OPA/Cedar.
Phase 3	Future	Immutable signed audit ledger with compliance-grade retention. Purview/DLP round-trip integration. Formal policy lifecycle: versioning, approvals, staged rollout.

NOTE

This document should be reviewed and updated in conjunction with any changes to the william-platform API contracts, the model_access_policy DynamoDB schema, or the Entra federation configuration.